

Narrativa Explicativa

De los Indicadores AMPARO-ENS a las Preguntas Incómodas (pero Necesarias)

Hay dos formas de hablar de ciberseguridad con la organización:

- 1) lanzarle un PDF del ENS a la cara y desearle suerte, o
- 2) hacerle preguntas concretas, medibles y, sobre todo, difíciles de esquivar.

Esta encuesta pertenece a la segunda categoría.

1. Por qué una encuesta y por qué así

El Esquema Nacional de Seguridad (ENS), actualizado por el Real Decreto 311/2022, insiste en la necesidad de evaluar regularmente el estado de seguridad y de disponer de métricas e indicadores estructurados. [web:30][web:32][web:33] El Centro Criptológico Nacional (CCN), a través de las guías CCN-STIC-815 y 824, va más allá: propone un sistema de medición que alimenta tanto la gestión interna como el Informe Nacional del Estado de Seguridad. [web:32][web:33][web:35][web:38]

INES y AMPARO, las herramientas que acompañan a este ecosistema, convierten esos principios en práctica: recoger datos, generar indicadores, planificar mejoras, documentar conformidad. [web:21][web:39] Ahora bien, para que todo esto funcione hace falta algo que no viene de serie: una conversación honesta dentro de cada organización.

La encuesta AMPARO-ENS está diseñada precisamente para provocar esa conversación.

2. Lo que se pregunta... y lo que en realidad se está preguntando

Cada bloque de la encuesta tiene un doble nivel:

- El explícito, que habla de políticas, SOC, MFA, DA, BCP, etc.
- El implícito, que interroga sobre gobernanza, prioridades, cultura y, en el fondo, sobre la manera en que la organización entiende la relación entre riesgo, servicio público y responsabilidad.

Por ejemplo:

- Cuando se pregunta si la política de seguridad está aprobada por el máximo órgano de gobierno, la cuestión real es si la seguridad es un tema de “TI” o un asunto de Estado (aunque ese Estado sea una pyme tecnológica que da servicio a un gran organismo).
- Cuando se pregunta por el uso de INES y AMPARO, la cuestión de fondo es si el ENS es un papel que se firma o un marco que se usa. [web:21][web:39]
- Cuando se explora el estado de Zero Trust, se está tanteando si la organización ha asumido que la confianza por defecto se ha acabado, al menos en redes y sistemas, aunque persista alegremente en algunas salas de reuniones. [web:11][web:15]

La ironía cortés que recorre algunas preguntas no es un adorno estilístico: es un recordatorio permanente de que medir sin pensar es solo burocracia, y pensar sin medir es rumorología.

3. De ENS a Zero Trust, pasando por el análisis de riesgos

El ENS nació en un mundo donde el perímetro todavía tenía algo de sentido; la realidad actual, empujada por la nube, el teletrabajo y las cadenas de suministro, exige modelos de confianza cero que verifican identidad, contexto y dispositivo de manera continua. [web:3][web:7][web:11][web:15]

La encuesta integra esta evolución:

- El bloque de análisis de riesgos pregunta por metodologías, registros y apetito de riesgo, en línea con las exigencias ENS y las buenas prácticas recogidas en la literatura y en herramientas como PILAR. [web:2][web:38]
- El bloque de Zero Trust la aterriza en controles concretos: MFA, segmentación, verificación contextual, monitorización. [web:11][web:15]
- El bloque de criptografía y riesgo cuántico introduce la incómoda idea de que los algoritmos que hoy nos protegen pueden ser, en unas cuantas iteraciones de hardware, papel mojado. [web:12][web:3]

No se trata de exigir que todas las entidades estén a la vanguardia absoluta, sino de recoger señales: quién está aún en el perímetro clásico, quién está en transición y quién empieza a hablar seriamente de post-cuántica.

4. Ciberresiliencia: más allá del incidente del mes

La ciberresiliencia ha dejado de ser palabra de moda para convertirse en criterio de madurez: una organización resiliente integra la seguridad en la continuidad, en la gestión de crisis y en la cultura general de la casa. [web:6][web:10]

Por eso el cuestionario no se limita a preguntar si hay incidentes, sino:

- Si se miden tiempos de detección y recuperación. [web:25][web:33]
- Si existen BCP/DRP que contemplen explícitamente ciberincidentes.
- Si se realizan simulacros que incluyan a la alta dirección (esa especie a veces esquivo cuando se trata de ejercicios de crisis).
- Si la ciberseguridad está sentada en la mesa donde se toman decisiones sobre continuidad de servicio.

La información que emerja aquí será especialmente valiosa a la hora de hablar con órganos de gobierno y reguladores, porque conecta controles técnicos con impactos sobre servicios esenciales y sobre la ciudadanía.

5. Métricas, IGM y el viejo sueño de cuantificar el riesgo

La guía CCN-STIC-815 insiste en distinguir entre datos, métricas e indicadores, y en que estos últimos deben estar vinculados a objetivos y decisiones. [web:32][web:35] La encuesta AMPARO-ENS recoge esa filosofía:

- Cada pregunta está pensada como fuente de datos.
- Las escalas y opciones se han diseñado para favorecer la construcción de métricas (por ejemplo, “nivel de implantación”, “frecuencia”, “cobertura”).
- Los indicadores sintéticos como el IGM son combinaciones ponderadas de esas métricas.

¿Es perfecto? No. ¿Es mejor que decidir inversiones de ciberseguridad por intuición, miedo escénico o última noticia de prensa? Sin duda.

Además, el modelo permite aproximarse a un cálculo razonable de **ROI en seguridad**: si sabemos qué controles faltan, cuáles son críticos y cómo se correlacionan con incidentes y tiempos de parada, podemos empezar a hablar en términos que las direcciones financieras entienden: coste de no hacer nada, coste de incidentes evitables, mejora esperada en los indicadores.

No se trata de convertir al CISO en actuario, pero tampoco de resignarse a ser el profeta apocalíptico con presupuesto limitado.

6. Comparación, benchmarking y mapa nacional

Uno de los rasgos diferenciales del ecosistema ENS-INES-AMPARO es la posibilidad de comparar manzanas con manzanas: entidades similares, con marcos normativos comunes, midiendo variables homologables. [web:21][web:39][web:33]

La encuesta contribuye a ese objetivo:

- Estandariza las preguntas sobre gobierno, riesgo, operación y cultura.
- Facilita la creación de índices por tipo de entidad, tamaño y sector.
- Ofrece material para mapas agregados de madurez y resiliencia a nivel nacional.

Por supuesto, todo esto requiere algo de disciplina metodológica y cierta contención a la hora de exhibir rankings. La idea no es repartir medallas, sino identificar brechas sistémicas y justificar decisiones de inversión, acompañamiento y supervisión.

7. Cómo leer los resultados (y cómo no)

Una advertencia útil para los futuros lectores:

- No leer los resultados como un veredicto inapelable, sino como un instrumento de trabajo. Un IGM bajo no es una condena, sino un argumento; uno alto, una responsabilidad.
- No confundir madurez formal con seguridad real: hay entidades con papeles impecables y prácticas discretas, y viceversa. La encuesta ayuda a acotar el problema, no a resolverlo mágicamente.
- No utilizar la métrica como arma arrojadiza entre departamentos: la experiencia internacional muestra que la seguridad mejora más con colaboración y transparencia que con ajustes de cuentas internos.

En positivo:

- Utilizar los resultados para priorizar proyectos, justificar recursos y negociar plazos.
- Incorporar los indicadores en informes ejecutivos que vayan más allá del “hemos tenido X incidentes” para hablar de tendencias, brechas y decisiones.
- Revisar periódicamente las respuestas para convertir la encuesta en una serie temporal y no en un one-shot.

8. Epílogo: lo que esta encuesta no puede hacer por usted

Hay tres cosas que ninguna encuesta, por buena que sea, podrá hacer:

1. Tomar decisiones en lugar de la dirección.
2. Sustituir auditorías, pruebas técnicas y evidencias.
3. Otorgar automáticamente el don de la previsión infalible.

Lo que sí puede hacer, y no es poco, es:

- Dar un lenguaje común para hablar de seguridad, riesgo y resiliencia.
- Conectar el ENS, las guías CCN-STIC, INES y AMPARO con la práctica diaria de quienes gestionan sistemas y servicios. [web:21][web:32][web:33][web:39]
- Poner en evidencia dónde falta gobierno, dónde sobran excusas y dónde hay margen de maniobra.

Si al terminar de completarla alguien en su organización dice “no sabía que estábamos así” o “esto explica por qué siempre vamos a remolque”, la encuesta habrá cumplido su función.

Si, además, alguien en la alta dirección pregunta “¿y qué hacemos ahora?”, será el momento de desplegar el resto del kit.